
Cloud Security Remediation Plan

AWS Assessment

Assessment Date: 2026-08-04

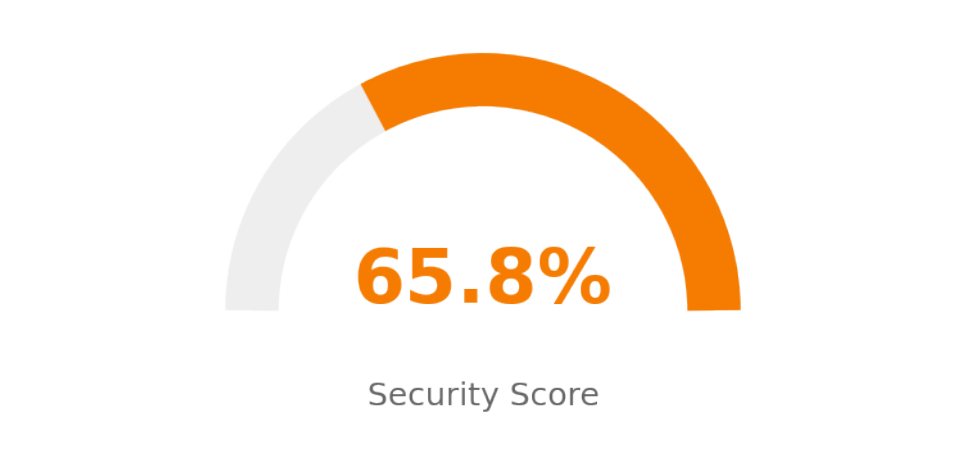
Cloud Provider(s): AWS

Account(s): Scope A, Scope B

Confidential — For Customer Use Only

1. Executive Summary

This remediation plan addresses findings from a security assessment of 2 account(s) on AWS, conducted on 2026-08-04. The assessment evaluated 16,485 security checks, achieving an overall security score of **65.8%**.

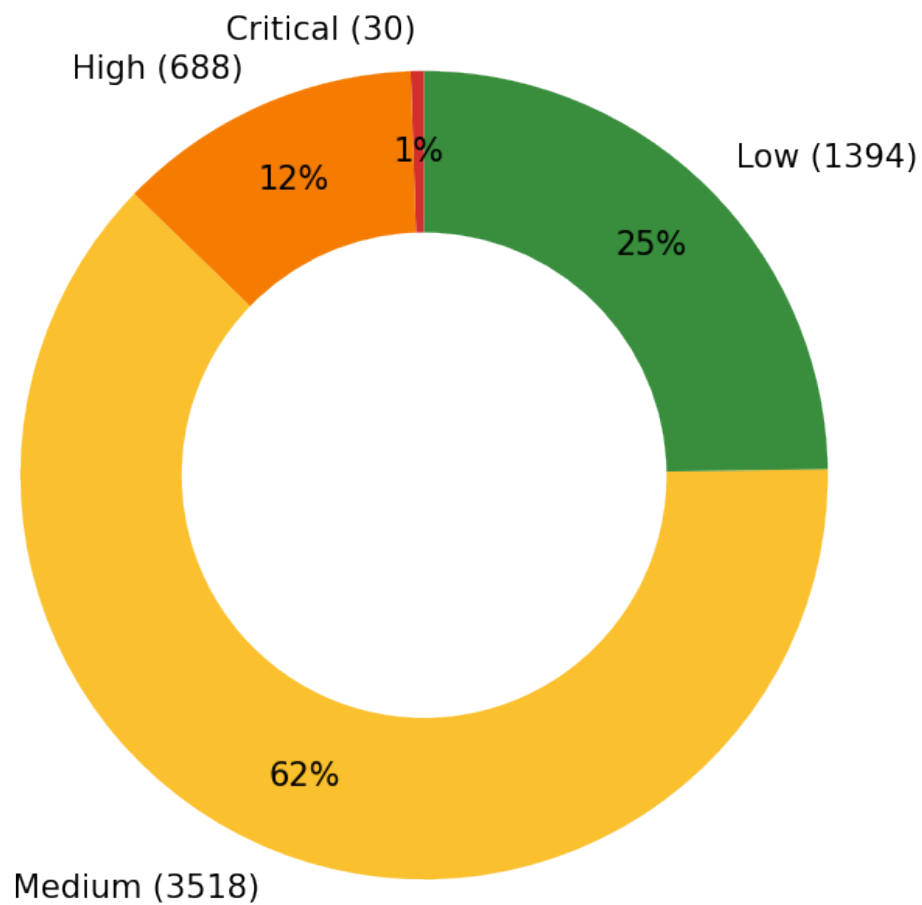


Metric	Value
Security Score	65.8%
Total Checks	16,485
Pass	10,849
Fail	5,630
Critical	30
High	688
Medium	3518
Low	1394

2. Findings Summary

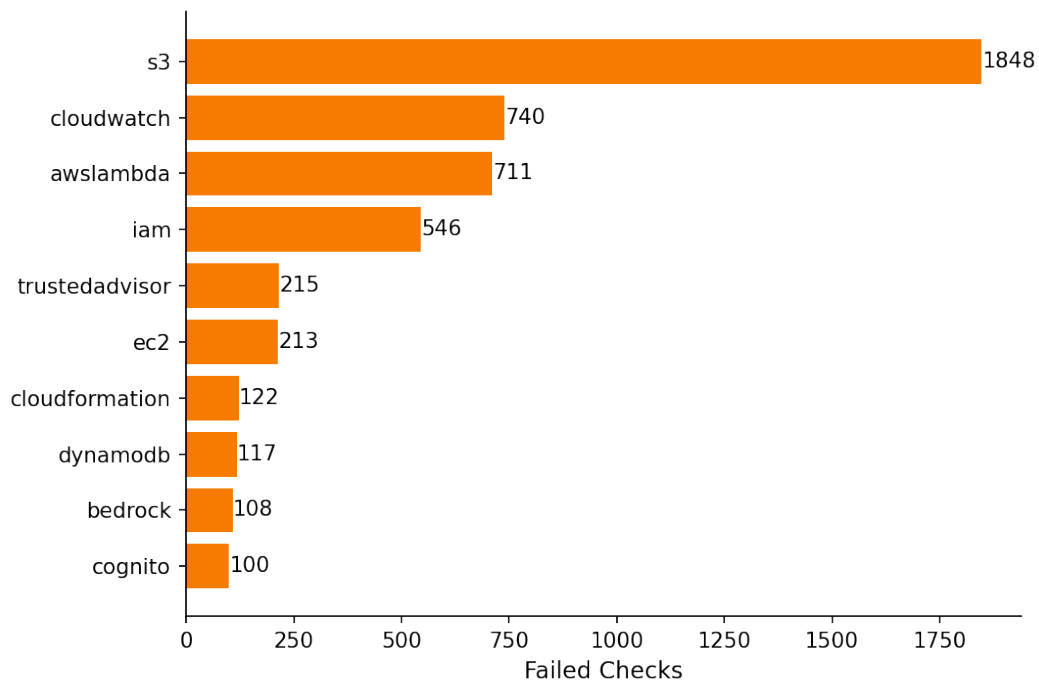
Findings by Severity

Findings by Severity



Top Services by Failed Checks

Top Services with Security Failures



Top Failed Security Checks

#	Check	Service	Severity	Count
1	CloudWatch log group is encrypted with an AWS KMS key	cloudwatch	Medium	496
2	IAM service role prevents cross-service confused deputy	iam	High	329
3	Trusted Advisor check has no errors or warnings	trustedadvisor	Medium	215
4	S3 bucket has MFA Delete enabled	s3	Medium	214
5	S3 bucket has Object Lock enabled	s3	Low	214
6	S3 bucket has cross-region replication configured to a	s3	Low	213
7	S3 bucket has event notifications enabled	s3	Low	201
8	S3 bucket has server access logging enabled	s3	Medium	192
9	S3 bucket has server-side encryption with AWS KMS	s3	Medium	191
10	Lambda function Invoke API calls are recorded by CloudT	awslambda	Low	182
11	S3 bucket has a lifecycle configuration enabled	s3	Low	180
12	Lambda function is deployed inside a VPC	awslambda	Low	177

13	Lambda function has a Dead Letter Queue configured	awslambda	Medium	177
14	S3 bucket policy denies requests over insecure transpor	s3	Medium	177
15	S3 bucket has object versioning enabled	s3	Medium	161

3. Phase 1: Immediate Actions (Day 1-3)

Address all Critical findings immediately — highest risk to the environment.

No findings at this severity.

4. Phase 2: Short-Term Actions (Week 1-2)

Address High severity findings within the first two weeks.

■ ■ IAM service role prevents cross-service confused deputy attack

Service: iam | Count: 329

Constrain service-role trust to expected callers using ``aws:SourceArn`/`aws:SourceAccount`` to bind service principals to specific resources or accounts. If unsupported, apply equivalent limits in resource-based policies or org-level controls. Apply **least privilege** and review trust relationships regularly.

5. Phase 3: Medium-Term Actions (Month 1)

Address Medium severity findings within the first month.

■ CloudWatch log group is encrypted with an AWS KMS key

Service: cloudwatch | Count: 496

Associate each log group with a **customer-managed KMS key** via `kmsKeyId`. - Enforce **least privilege** in key and IAM policies, granting `kms:Decrypt` only to required principals - Enable rotation and monitor key usage - Separate keys by app/tenant to support **defense in depth** and rapid revocation

■ Trusted Advisor check has no errors or warnings

Service: trustedadvisor | Count: 215

Adopt a continuous process to remediate Trusted Advisor findings: - Prioritize **error** then **warning** - Assign ownership and SLAs - Integrate alerts with workflows - Enforce **least privilege**, segmentation, encryption, MFA, and tested backups - Reassess regularly to confirm fixes and prevent regression

■ S3 bucket has MFA Delete enabled

Service: s3 | Count: 214

Enable **MFA Delete** on sensitive, versioned buckets so permanent deletions and `Versioning` changes require a second factor. Apply **least privilege** to restrict version purge actions, enforce **change control**, and combine with **Object Lock** or immutable backups for defense in depth.

■ S3 bucket has server access logging enabled

Service: s3 | Count: 192

Enable **server access logging** and send logs to a dedicated log bucket with least privilege, retention, and monitoring. Complement with **CloudTrail data events** for object-level visibility. Apply **defense in depth** by centralizing logs and protecting them from tampering.

■ S3 bucket has server-side encryption with AWS KMS

Service: s3 | Count: 191

Enable default **SSE-KMS** (or **DSSE-KMS** for highly sensitive data). Use a customer-managed key, enforce **least privilege** and separation of duties for key usage, and require KMS encryption via bucket policy (specify `aws:kms` and a designated key). Monitor key activity in **CloudTrail** and consider **S3 Bucket Keys** to control cost.

■ Lambda function has a Dead Letter Queue configured

Service: awslambda | Count: 177

Configure a Dead Letter Queue for every Lambda function that handles asynchronous invocations. - Prefer an **SQS queue** as the DLQ target for retry and replay capability - Ensure the Lambda execution role has `sqs:SendMessage` permission on the DLQ - Monitor DLQ depth with a CloudWatch alarm to alert on processing failures

6. Phase 4: Ongoing Governance

- Schedule periodic Prowler re-assessments (monthly or quarterly)
- Enable continuous compliance monitoring (AWS Config)
- Enable native threat detection (GuardDuty)
- Centralize findings management for the assessed environment
- Establish a security review cadence with stakeholders
- Automate remediation with policy-as-code
- Rotate credentials/keys on a regular schedule
- Monitor audit logs for unauthorized activity

7. Risk Matrix

Severity	Count	Impact	Urgency	Action
Critical	30	Data breach, scope compromise	Immediate	Day 1-3
High	688	Unauthorized access, data exposure	High	Week 1-2
Medium	3518	Compliance gaps, misconfigurations	Medium	Month 1
Low	1394	Best-practice deviations	Low	Ongoing

8. Compliance Gap Analysis

Framework	Total	Pass	Fail	Pass Rate
NIS2	10328	6702	3608	64.9%
KISA-ISMS-P	84196	60990	22888	72.4%
AWS-AI-Security-Framework	9352	5685	3625	60.8%
AWS-Account-Security-Onboarding	2521	1476	973	58.5%
FedRAMP-20x-KSI-Low	6086	4273	1813	70.2%
AWS-Foundational-Security-Best-Practices	5662	3203	2293	56.6%
MITRE-ATTACK	23079	18941	4058	82.1%
AWS-Well-Architected-Framework-Reliability-Pillar	300	22	341	6.1%
CSA-CCM	30719	18884	11827	61.5%
CIS	11925	7197	4688	60.4%

9. Success Metrics

- Security Score Target: $\geq 90\%$ (current: 65.8%)
- Critical findings: 0 within 3 days
- High findings: 0 within 2 weeks
- Mean-time-to-remediate (MTTR): < 48 hours for Critical
- Compliance pass rate: $\geq 85\%$ across all frameworks
- Re-assessment frequency: Monthly

10. Appendix: Terraform Module Reference

Terraform remediation modules are provided in the `iac/` directory. Each module targets a specific security control and includes variables, deployment commands, rollback instructions, and validation steps. Refer to the README for full details.

■■ The Terraform modules are auto-generated and touch sensitive controls (identity, network, logging, encryption). Review each module and run **terraform plan** before **apply**.